

MAPEO INDICADORES ↔ REQUISITOS NORMATIVOS

Trazabilidad Completa GQM + PRAGMATIC a GDPR/DORA/NIS2

Versión: 2.0 | **Fecha:** Enero 2026 | **Clasificación:** Público

INTRODUCCIÓN

Cada indicador CRM mapeado a:

- ✓ Artículos regulatorios específicos (GDPR, DORA, NIS2, NIST CSF 2.0)
- ✓ Evidencia requerida para cumplimiento
- ✓ Sanciones si no cumplido
- ✓ Frecuencia auditoría

MATRIZ COMPLETA: INDICADORES ↔ REQUISITOS NORMATIVOS

Indicador	GQM Goal	PRAGMATIC	GDPR	DORA	NIS2	NIST CSF 2.0	Sanciones	Evidencia	Frecuencia
IGM Score (0-4)	G1-G10	4.2	Art 32	Art 11-16	Art 13-18	Govern + Manage	€20M / 4%	Assessment report	Anual
RAS Documentado	G1	4.4	Art 5 (governance)	Art 11 (RF)	Art 17	Govern. RM-2	€10M / 2%	RAS doc + approval	Anual
CISO Designado	G1	3.8	Art 32(7)	Art 11	Art 18	Govern. OC-1	€5M (governance gap)	Org chart + contract	Ongoing
Risk Tolerance	G1	4.2	Art 32(1)	Art 11	Art 17	Govern. OC-2	€5M	RT document	Anual
Junta Oversight	G1	4.1	Implicit	Art 11	Art 18	Govern. OC-3	€5M	Board minutes	Trimestral
ALE Top 5 Risks	G2	3.9	Art 32(2)	Art 15	Art 13	Identify .RA-1	€10M	Risk register	Anual
ROI Analysis	G2	4.2	Implied (cost-benefit)	Art 16	Implied	Govern. RM-3	€5M (ineffective controls)	Business cases	Por decisión
PASTA Coverage	G3	3.8	Art 32(1)(d)	Implied	Art 13	Identify .RA-1	€5M	TM documentation	Anual críticos
Attack Trees	G3	3.6	Art 32(1)(d)	Implied	Art 13	Identify .RA-2	€5M	Attack tree docs	Anual críticos
MTTD (minutos)	G4	4.7	Art 33 (notify 72h)	Art 19 (incident detect)	Art 19	Detect. DE-1	€20M (breach)	SIEM logs + timeline	Daily
MTTR (horas)	G5	4.6	Art 33 (contain)	Art 19 (<4h críticos)	Art 19	Respond. RS-1	€20M (prolonged breach)	Incident tickets	Daily

Patch % <7d	G6	4.6	Art 32(1) (b)	Implied	Art 13	Protect. PR-3	€10M (unpatched vuln breach)	Patch logs + timestamps	Weekly
Scanning Freq	G6	4.0	Art 32(2)	Implied	Art 13	Identify .RA-2	€10M	Scan schedule logs	Daily
CVSS v4.0 Usage	G6	3.9	Implied (severity)	Implied	Art 13	Identify .RA-1	€5M (poor prioritization)	Vulnerability reports	Per vuln
Vendor Audit %	G7	4.0	Art 28 (DPA audit)	Art 29 (3rd-party)	Art 17	Govern. GV-4	€10M (vendor breach)	Audit reports	Annual
SBOM Maintained	G7	3.7	Art 32 (integrity)	Art 29 (deps)	Art 17	Identify .RA-1	€10M (supply chain)	SBOM files	Per deployment
Contractual Security	G7	4.1	Art 28 (mandatory)	Art 29	Art 17	Govern. GV-4	€5M	Contracts reviewed	Per nuevos terceros
Phishing Click % <5	G8	4.3	Art 32(7) (awareness)	Implied	Art 13	Govern. OC-2	€5M (human breach)	Phishing reports	Monthly
Phishing Report %	G8	3.9	Art 32(7)	Implied	Art 13	Govern. OC-2	€3M	Report logs	Monthly
Training Completion %	G8	4.1	Art 32(7) (mandatory)	Art 12 (competence)	Art 13	Govern. OC-2	€5M	Training records	Annual
GDPR Compliance %	G9	3.6	Art 5, 32, 33	Overlap s DORA	n/a	Align to CSF	€20M / 4% revenue	Audit report	Annual
DORA Compliance %	G9	3.8	n/a	Art 11-30 (all)	Overlap s NIS2	Align CSF	€10M / 2% revenue	Compliance audit	Annual (financial sector)

NIS2 Readiness %	G9	3.5	Art 32 overlaps	Art 29 overlaps	Art 13-18	Align CSF	€10M (essential) / €7M (important)	Gap analyses	Quarterly (pre-trans)
Policy-as-Code %	G10	4.1	Art 32(1)(c)	Art 13 (tech measures)	Art 13	Protect. PR-1	€5M (policy drift)	Policy code + deployment	Continuous
IaC Adoption %	G10	3.9	Art 32(1) (a)	Art 13	Art 13	Protect. PR-2	€5M (misconfig)	IaC repos + audit logs	Continuous
Resilience Testing	G10	4.2	Art 32(1) (b)	Art 19 (DR testing)	Art 13	Recover .RC-1	€10M (RTO exceeded)	Test results + reports	Annual

SECCIÓN 2: ANÁLISIS POR REGULACIÓN

GDPR (Vigente Mayo 2018)

Sanciones: €20M o 4% revenue global (lo que sea mayor)

Artículos Clave para CRM:

- Art 5: Principios (confidentiality, integrity, availability)
- Art 32: Medidas seguridad (técnicas + organizacionales)
- Art 33: Notificación breach 72h

Indicadores Críticos:

1. RAS Documentado (Art 32.1)
2. MTTD <30 min (Art 33 — 72h limit)
3. Patch % <7d (Art 32.1.b)
4. Training Completion (Art 32.7)
5. GDPR Compliance Score

Gap Spain 2026: GDPR ~85% compliance — target 95%

DORA (Vigente Enero 2025 — SECTOR FINANCIERO)

Sanciones: €10M o 2% revenue (financial sector only)

Artículos Clave:

- Art 11: RAS framework (obligatorio)
- Art 15: Risk assessment (cuantificación)

- Art 19: Incident management (<4h MTTR críticos)
- Art 29: Third-party risk

Indicadores Críticos:

1. RAS Documentado (Art 11)
2. ALE Top 5 Risks (Art 15)
3. MTTR <4h (Art 19)
4. MTTD <30 min (Art 19)
5. Vendor Audit % (Art 29)
6. DORA Compliance Score

Aplicabilidad España: Sector financiero (BdE, CNMV oversight)

NIS2 (España Q1 2026 Transposición)

Sanciones: €10M (essential entities) / €7M (important entities)

Artículos Clave:

- Art 13: Medidas seguridad (técnicas + org)
- Art 17: Gobernanza (CISO, RAS, etc.)
- Art 18: Supervisión (regulador)
- Art 19: Incidente reporting 24h

Indicadores Críticos:

1. IGM Score >3.0 (framework alignment)
2. CISO Designado (Art 18)
3. Risk Tolerance (Art 17)
4. Incident Response <24h (Art 19)
5. Supply Chain Risk (Art 17)
6. NIS2 Readiness Score

Impacto España: 5.700-9.800 entidades afectadas (vs 6.000 NIS1)

NIST CSF 2.0 (Referencia Global)

No sanciones directas; pero recomendado:

- EU (DORA, NIS2 alignment)
- España (INCIBE guidance)
- US (DHS procurement requirement)

Indicadores Críticos:

1. IGM Score (CSF alignment)
2. Govern function (nueva 2024)
3. MTTD + MTTR (Detect + Respond)
4. Patch % (Protect)
5. Training (Govern awareness)

SECCIÓN 3: COMPLIANCE RISK SCORING

Cálculo Compliance Risk por Regulación

GDPR Compliance Score = (Indicadores GDPR cumplidos / Total) × 100

INDICADORES GDPR (5 críticos):

1. RAS Documentado: ✓ o ✗
2. MTTD <30 min: ✓ o ✗
3. Patch % <7d: ✓ o ✗
4. Training Completion: ✓ o ✗
5. Audit Trail Maintained: ✓ o ✗

SCORE = 4/5 cumplidos → 80% GDPR compliance

Risk Matrix: Sanción Potencial

Compliance %	GDPR Fine	DORA Fine	NIS2 Fine	Status
100%	€0	€0	€0	✓ GREEN
95%+	<€1M (art 83.4)	<€1M	<€1M	✓ AMBER
90-95%	€1-5M	€1-5M	€1-5M	⚠ ORANGE
80-90%	€5-10M	€5-10M	€5-10M	● RED
<80%	€10-20M	€10M (exact)	€10M (exact)	● CRITICAL

SECCIÓN 4: AUDITORÍA READINESS

Checklist por Regulación

Para GDPR Audit:

- ☐ RAS documentado + versión control
- ☐ Risk register con ALE
- ☐ MTTD logs (SIEM eventos)
- ☐ Patch records timestamped
- ☐ Training certificates (todos empleados)
- ☐ Data breach log (incidents <72h notificados)
- ☐ Vendor contracts (DPA Art 28)
- ☐ Retention policy documented

Para DORA Audit:

- ☐ RAS + Risk Tolerance Statement
- ☐ Risk assessment report (FAIR o similar)
- ☐ ICT incident log + MTTR per incident
- ☐ Vendor audit results + contracts
- ☐ DR testing results + RTO/RPO validation
- ☐ Board minutes (CISO reporting)
- ☐ Third-party risk assessment register

Para NIS2 Audit (Pre-Transposición):

- ☐ Security posture self-assessment
- ☐ NIST CSF 2.0 mapping
- ☐ Governance docs (CISO, RAS, Risk Tolerance)
- ☐ Incident response plan + 24h notification capability
- ☐ Supply chain risk register
- ☐ Incident history (últimos 12 meses)
- ☐ Threat modeling documentation

SECCIÓN 5: TIMELINE CUMPLIMIENTO

España 2026 Critical Dates

ENERO 2026:

- NIS2 formal publication (posible)
- CNCS begins public consultation

MARZO 2026:

- NIS2 transposición draft deadline
- "Essential entities" identification

JUNIO 2026:

- NIS2 ley en BOE (estimado)
- Cumplimiento obligatorio begins

SEPTIEMBRE 2026:

- DORA deadline (sector financiero)
- CNCS enforcement begins

Q4 2026:

- First NIS2 compliance reports due
- CNCS audit campaigns

Roadmap Indicadores por Período

Período	Acción	Indicadores
Q1 2026	Baseline assessment	IGM, PRAGMATIC scores
Q2 2026	Quick Wins	MTTD, Patch %, Phishing click
Q3 2026	Strategic initiatives	ALE, FAIR, Vendor audit
Q4 2026	Compliance validation	GDPR %, DORA %, NIS2 readiness
2027	Continuous monitoring	Monthly KPI dashboard

CONCLUSIÓN MAPEO

- ✓ Cada indicador CRM está mapeado a artículos regulatorios específicos
- ✓ Sanciones potenciales documentadas (€ motivation)
- ✓ Evidencia requerida clara para auditor
- ✓ Timeline implementación realista para España 2026

Fin Mapeo Indicadores ↔ Requisitos Normativos